



University of Minho
School of Engineering



Cryptography & Network Security

Bachelor in Telecommunications and Informatics Engineering

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

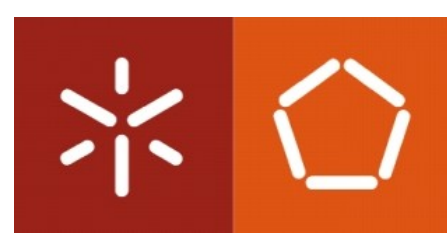
2024/2025



Digital Certificates



Digital Certificates



Recap

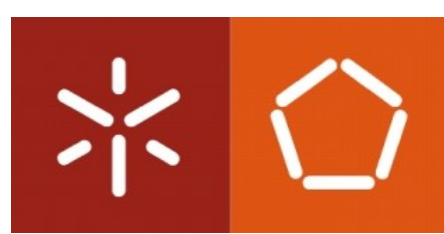
- Establish the association between a public key and its corresponding private key holder.
- An external trusted entity, i.e., the Certification Authority (CA), is used to guarantee these associations.
 - The Public-Key Certificates, which are signed by the trusted entity, confirm this association.
 - Users consider this association valid due to their trust in the CA.
 - They confirm the certificate's validity by verifying its signature using the CA's public key.



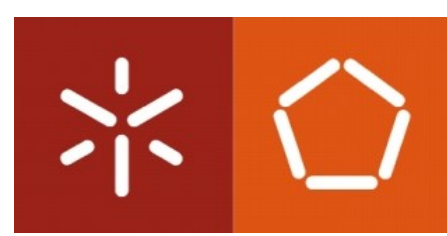
Digital Certificates

Recap

- No secure channels are needed to transmit the certificates.
- Certification Authorities' role in the security of the entire system is critical.
- It is usual for the CA to impose very high security standards.
 - Hardware Security Modules (HSM)
 - Physical security
 - Strict security plans
- Operated by a Public-Key Infrastructure (PKI)



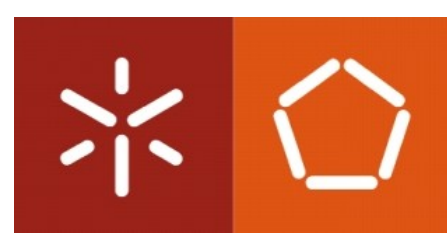
Public-Key Infrastructure



A set of procedures, technologies and services used to create, manage, distribute, use, store, and revoke public-key certificates.



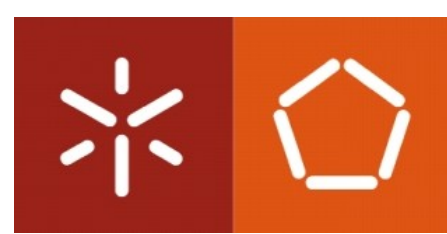
Public-Key Infrastructure



- The large-scale use of Public-Key Certificates relies on a solid basis for establishing and systematizing:
 - Formats and technologies;
 - Conventions and assumptions;
 - Practices and procedures;
 - Regulatory and legal framework.
- A PKI bridges the gap between concepts and elements of a technological nature (i.e., cryptographic keys) with aspects that are ultimately “social” in nature (i.e., identity).



Public-Key Infrastructure

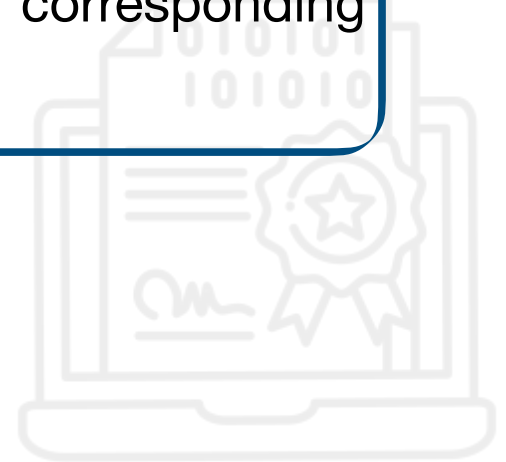


Main components

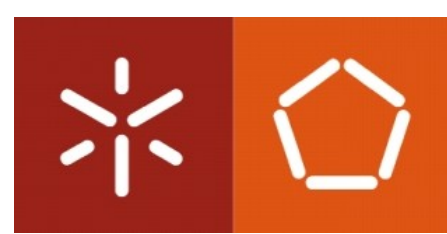
Certificate Authority (CA): The trusted entity that issues, revokes, and manages digital certificates. It also validates the identity of entities requesting certificates and signs them with its private key.

Registration Authority (RA): Acts as an intermediary between the end users and the CA. It helps with identity verification of certificate requests before they reach the CA. While the CA performs the actual certificate issuance, the RA handles tasks like identity verification and request approval.

Digital Certificate: A set of data that uniquely identifies a public key that has a corresponding private key and an owner that is authorized to use the key pair.



Public-Key Infrastructure

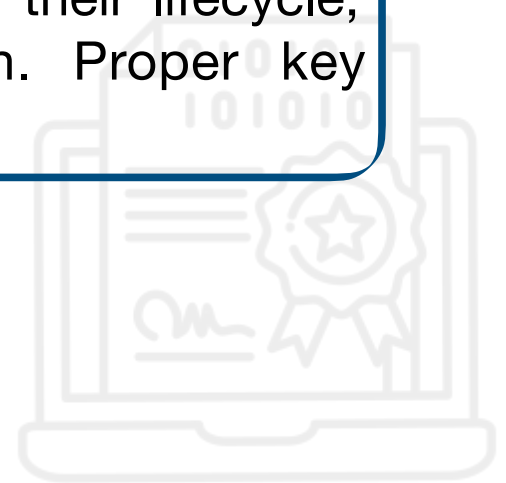


Main components

Certificate Revocation List (CRL): A list published by a CA of certificates revoked before their expiration date. Reasons for revocation can include compromised keys, user status changes, or CA policies.

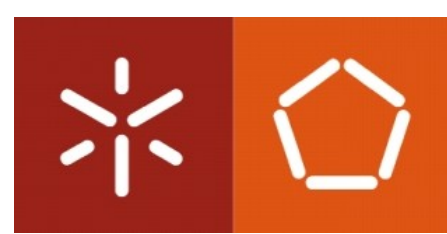
Online Certificate Status Protocol (OCSP): An internet protocol used to obtain the revocation status of a certificate in real-time. Unlike CRL, which is a static list, OCSP provides more immediate and dynamic certificate status checks, improving security by allowing quick validation.

Key Management System (KMS): Responsible for managing keys throughout their lifecycle, including key generation, distribution, backup, recovery, and destruction. Proper key management is essential to maintain the integrity and security of PKI.



Public-Key Infrastructure

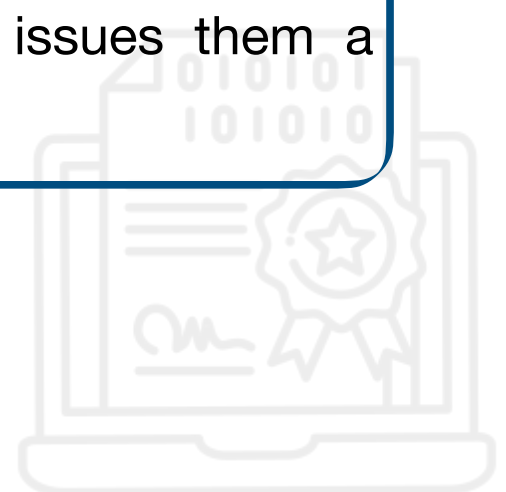
Operations



Initialization: The initial process that enables user communication with the PKI by identifying trusted CAs and obtaining their corresponding public keys and certificates.

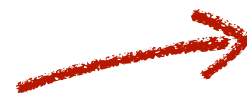
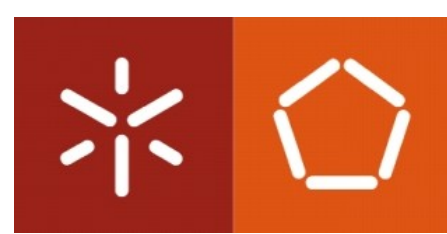
Certificate request: Having their key pair, the user requests a CA to certify their public key through a certificate request (CSR).

Registry: A user authenticates with a CA (directly or via an RA) so that it issues them a certificate.



Public-Key Infrastructure

Operations

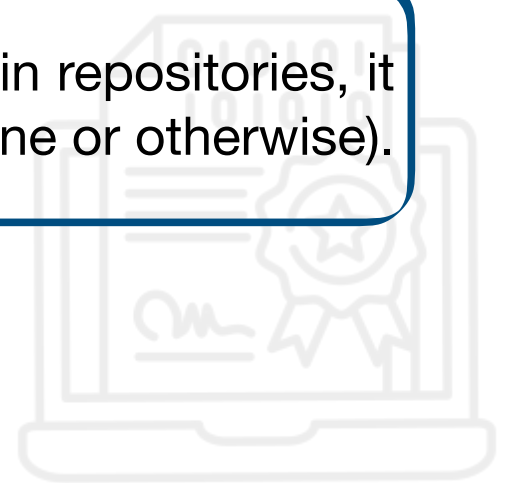


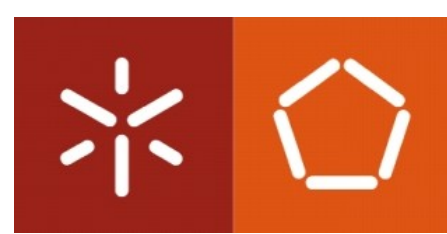
How secure is this approach?

Key pair generation: In some implementations, the CA generates the users' key pairs, which are sent securely along with the certificate.

Certification: The CA receives the user's public key and identification and issues the respective certificate, according to internal rules.

Publishing Certificates and CRLs: In addition to placing certificates and CRLs in repositories, it is often necessary to provide these documents to end users by other means (online or otherwise).





Public-Key Infrastructure

Operations

Revocation: It may be necessary to revoke the certificate before its expiration for various reasons, e.g., when attributes are no longer valid or when the private key has been compromised.

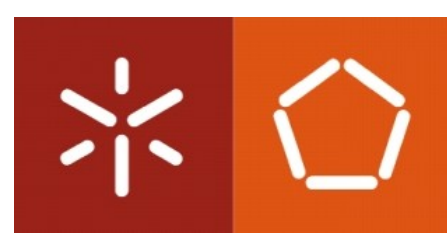
Recovering a Key Pair: In some implementations, CAs securely store the entity's key pair as backup and protection (e.g., a company and its employees). In these cases, the key pair can be restored in the event of its loss or damage.

Certificate renewal and/or Key Pair update: Once the validity of a certificate has expired, a new one needs to be issued. The user's public key may or may not be kept in this process.



Public-Key Certificates

X.509

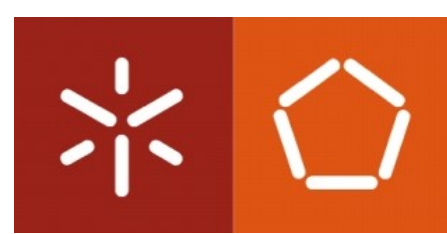


- The X509 Certificates are an instance of the public-key certificates introduced to authenticate the nodes of the X500 service.
- Data is represented as “key-value” data structures (dictionaries).
- The coding of this data is standardized, guaranteeing its interoperability.
 - **DER**: binary format defined by the standard (ASN.1 notation).
 - **PEM**: representation of the information contained in the DER format in printable characters.
- The certificate is signed by the certification authority on the DER encoding of the data it contains.



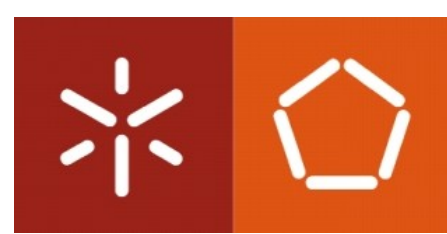
Public-Key Certificates

X.509v3



- The current version of certificates, standardized in 1996, extends the number of attributes in early versions.
- Introduced the new field *Extensions*, enabling the required flexibility for new uses.
 - Allow generic attributes to be associated with an entity or its public key.
 - Each extension is a self-contained data structure with an identifier and a value appropriate to the attribute it represents.



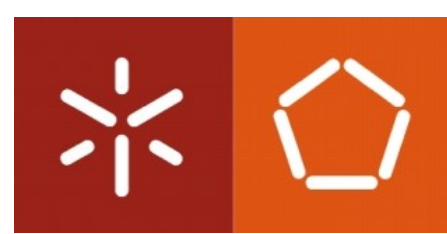


Public-Key Certificates

X.509v3 Basic attributes

- **version** - Standard version X509(v3).
- **serialNumber** - Unique number assigned by the CA to the certificate.
- **subject** - Identification of the public key holder included in the certificate.
- **subjectPublicKeyInfo** - Structure containing the certificate holder's public key and the identification of the corresponding algorithm.



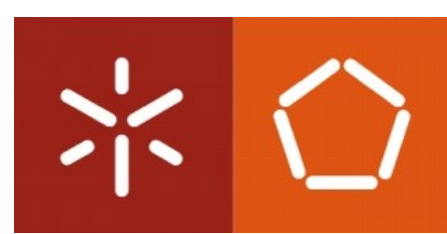


Public-Key Certificates

X.509v3 Basic attributes

- **issuer** - Identification of the CA issuing the certificate.
- **signature** - Structure that identifies the algorithm used to generate the CA's signature that is attached to the certificate.
- **validity** - Structure with the two dates that delimit the validity period of the certificate.
 - **notBefore**
 - **notAfter**



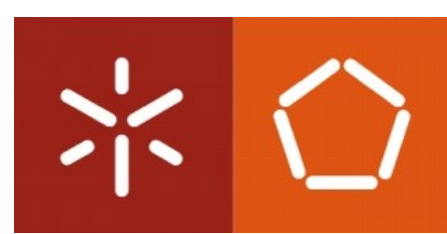


Public-Key Certificates

X.509v3 Extensions

- RFC5280 defines several certificate extensions indicating how the certificate should be used.
- Extensions are marked as **Critical** or **Non-Critical**. An application that encounters an unrecognized critical extension should reject the certificate.
- **Basic Constraints** - Used to indicate whether the certificate is a CA certificate and can certify or issue other certificates.
- **Certificate Policies** - Used to include information on the certification policies applicable to the certificate.



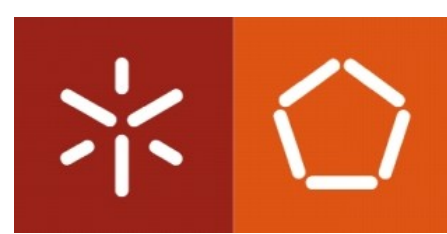


Public-Key Certificates

X.509v3 Extensions

- **Key Usage** - Describes the cryptographic operations that can be executed using the public key in the certificate.
- **digitalSignature** - Digital signatures for authentication and data integrity, except certificates and CRLs.
- **nonRepudiation** - Digital signatures for non-repudiation purposes.
- **keyEncipherment** - Protection of key confidentiality.
- **dataEncipherment** - Protection of data confidentiality.



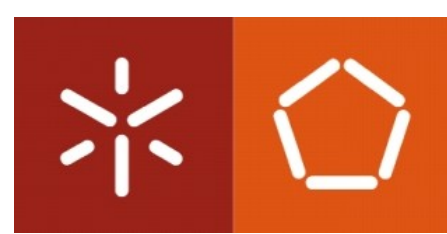


Public-Key Certificates

X.509v3 Extensions

- **Key Usage** - Describes the cryptographic operations that can be executed using the public key in the certificate.
 - **keyAgreement** - Key agreement protocols.
 - **keyCertSign** - Certificate signature.
 - **cRLSign** - Signing certificate revocation lists.
 - **encipherOnly/decipherOnly** - Restricts the **keyAgreement** functionality.



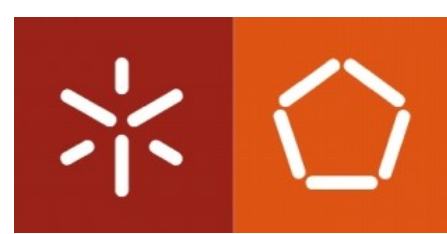


Public-Key Certificates

X.509v3 Extensions

- **Extended Key Usage** - Indicates the purpose of the public key contained in the certificate by using a list of OIDs, each indicating an allowed use.
 - `WWW server authentication`
 - `WWW client authentication`
 - `Signing of downloadable executable code`
 - `E-mail protection`
- **CRL Distribution Points** - Indicates to certificate users where they can obtain information about a certificate revocation as a CRL.





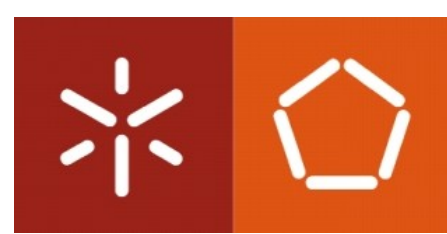
Public-Key Certificates

Certification and Trust chains

- To use a service that requires a public key, it is necessary to obtain and validate its certificate.
- Validating the certificate implies knowing the public key of the Certification Authority that issued it.
 - The public key is already known to the user (e.g., it has been securely pre-installed).
 - or it is also provided via a certificate issued by another CA.
 - It requires validating the certificate

This is a recursive procedure that ends when a certificate from an already trusted CA is reached.

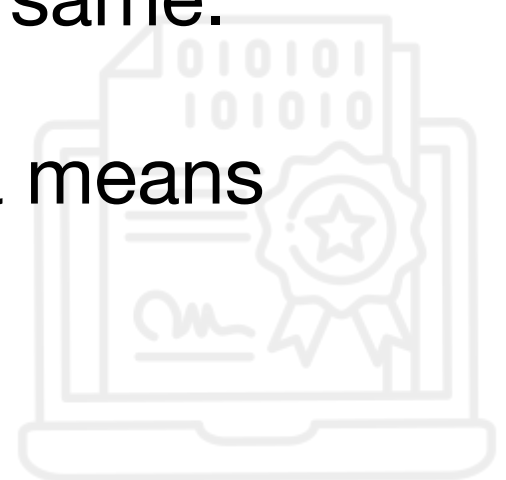




Public-Key Certificates

Certification and Trust chains

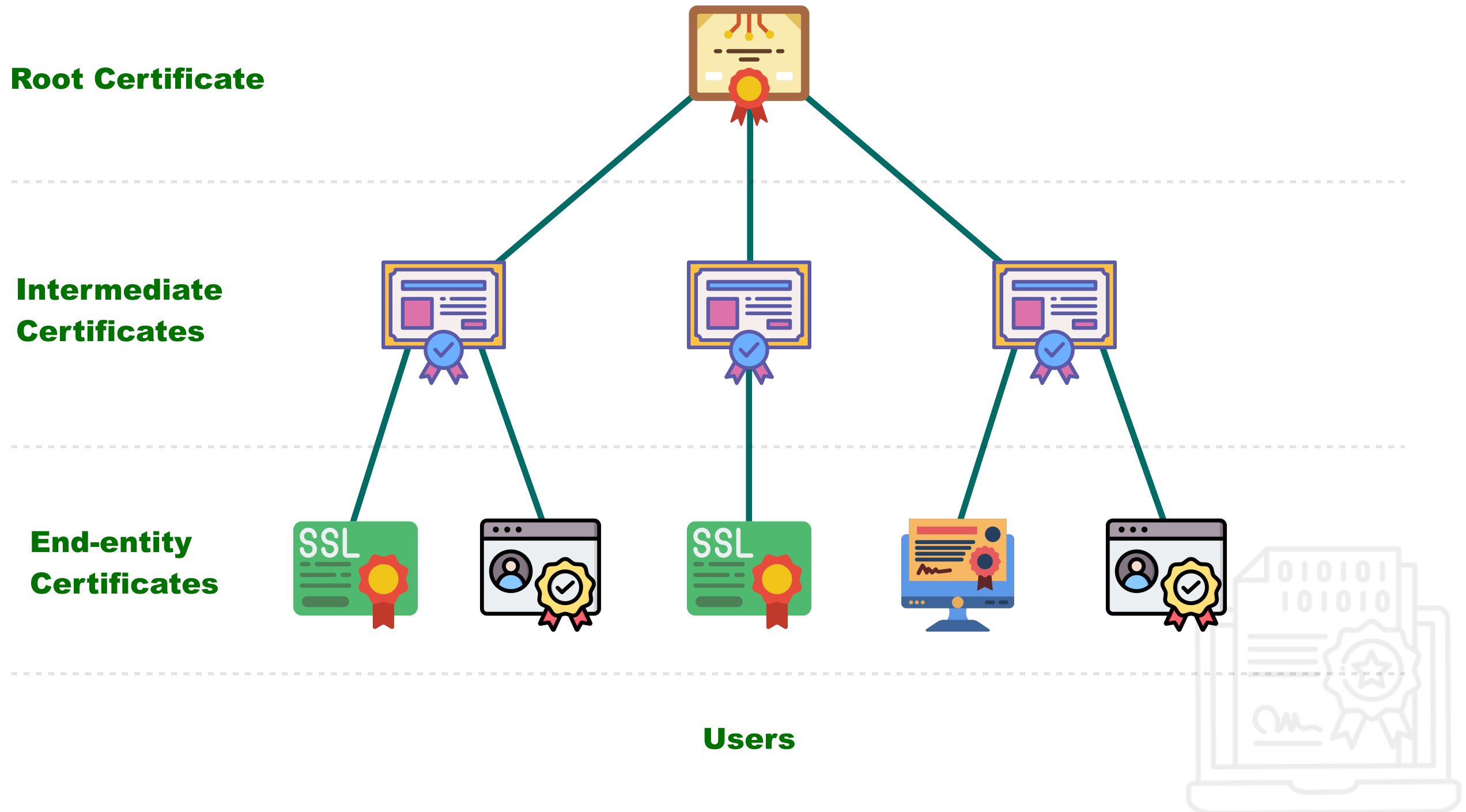
- In a well-formed certification chain, the `issuer` of a certificate should be the `subject` of its predecessor.
- Certification chains reflect a hierarchy of Certification Authorities: hierarchically superior CAs issue the certificates of hierarchically inferior CAs.
- At the top of the hierarchy is a CA called Root. Its certificate is issued and signed by itself - in other words, a self-signed certificate, i.e., its `subject` and `issuer` fields are the same.
- Trust in the public key of a Root CA is established by a means external to the PKI.

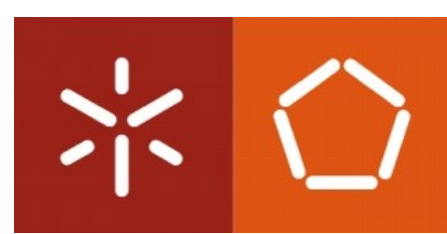




Public-Key Certificates

Certification and Trust chains





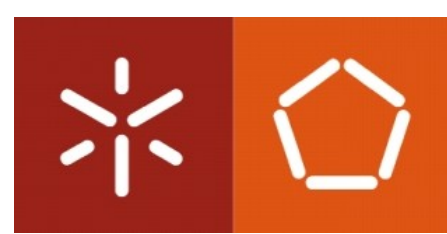
Public-Key Certificates

Validating certificates

- For each certificate in the certification chain, check:
 1. Validity of the signature
 2. The applicability of the certificate (based on its extensions)
 3. If it has not been revoked (e.g., by consulting CRL)
- The root of the certification chain should be a CA whose public key is already known - this is called the root or anchor of the trust chain.



Public-Key Certificates

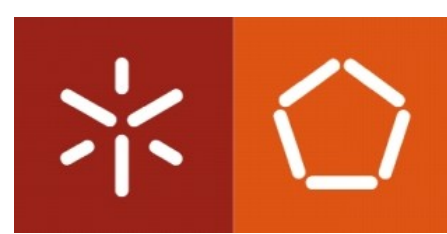


Trust anchor

- A user knows a limited number of public keys belonging to root trusted entities, which act as the roots of trust chains.
- This means that the user will accept a certificate issued by one of these CAs and place a certain level of trust in its content.
- A certificate chain validation ends when a certificate with this characteristic is found.

The level of trust placed in a valid certificate is ultimately based on the trust placed in the CA that acted as the root of the chain.



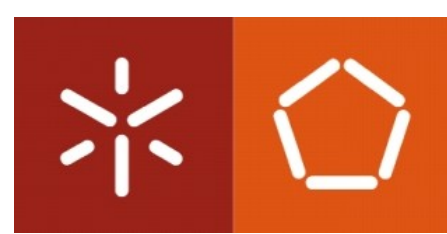


Public-Key Certificates

Certificate profiles

- The X509v3 standard offers the flexibility to define extensions tailored to specific needs.
- The semantics of these attributes are, therefore, “open” but must be fixed by rules that establish, in a given context, which attributes must be present and what their meaning is.
- Examples
 - Email protection (S/MIME)
 - Site authentication (TLS-server)
 - Authentication to Services (TLS-client)
 - Qualified Signature of Documents

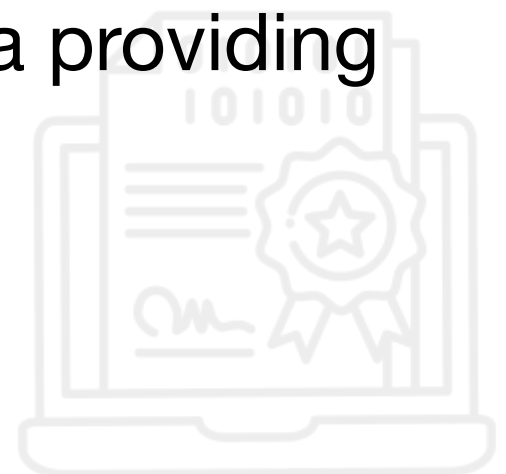


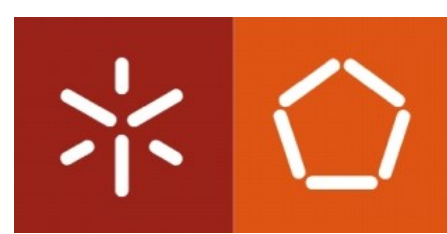


Public-Key Certificates

Example - TLS certificate

- Identity validation methods - Issuing process
 - **Domain Validation (DV)** - Identity verified solely based on evidence of control of the DNS domain.
 - **Organization Validation (OV)** - Verifies the control of an organization (e.g., company, public body, etc.).
 - **Extended Validation (EV)** - Stricter validation criteria providing evidence of legal control over the entity.



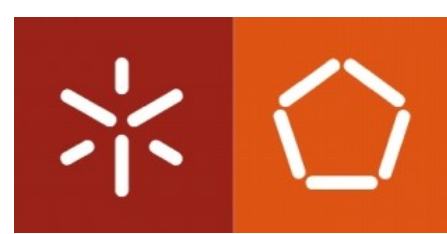


Public-Key Certificates

Certificate revocation

- Sometimes, there is a need to revoke certificates that are still valid.
- Reasons for revoking certificates:
 - Compromised private key.
 - Conditions justifying the association of the issuer with the public key are no longer present (e.g., the issuer holds a temporary position).
 - The data contained in the certificate is no longer correct.
- The original mechanism for revoking certificates is the Certificate Revocation List (CRL).

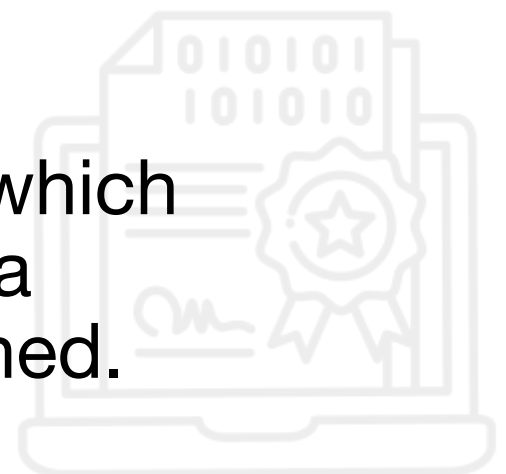


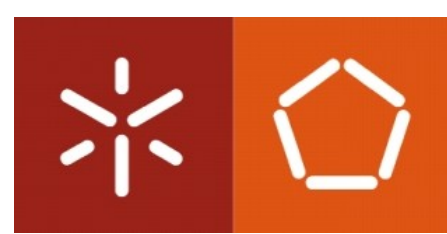


Public-Key Certificates

CRL

- Certificate Revocation Lists (CRL) are the channel provided in X.509 for revoking certificates within their validity period. The CRL can be:
 - **Base CRL** - When it lists all the certificates revoked by a CA that are still valid.
 - **Delta CRL** - When it only lists certificates revoked since the publication of a referenced CRL Base.
- CRLs are typically issued and signed by the CAs or a delegated authority (i.e., CRL Issuer).
- The security of a PKI depends on the effectiveness with which certificates that have become invalid are revoked. When a certificate becomes invalid, a new CRL should be published.



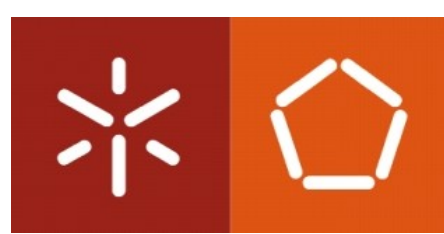


Public-Key Certificates

Online Certificate Status Protocol (OCSP)

- As an alternative or addition to consulting a CRL, up-to-date information on the revocation status of a certificate may be required.
- OCSP, as defined in RFC6960, allows applications to determine the status of a certificate more frequently.
- The OCSP Client issues a request to an OCSP Responder (Server) and suspends acceptance of the certificate until it provides a response.
 - **Is this how browsers work these days?**
- Services similar to OCSP are also planned for Delegated Path Validation and Delegated Path Discovery (RFC3379).

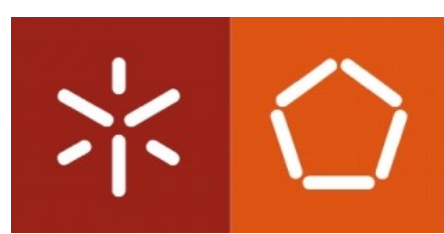




Hands-on

Select an online service you use frequently and inspect its Digital Certificate. What extensions are used? Can you identify the chain of trust?

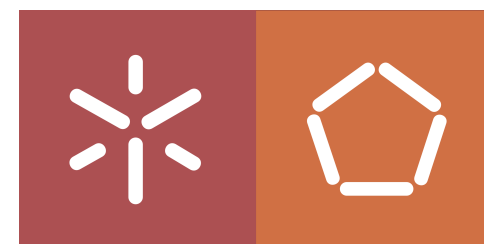




Hands-on

Using the Cryptography library (python) or OpenSSL (other languages). Create and validate a certificate hierarchy where an intermediate CA issues certificates to clients and guarantees its trust through a certificate issued by a Root CA.





University of Minho
School of Engineering



Cryptography & Network Security

Bachelor in Telecommunications and Informatics Engineering

João Marco Silva

Department of Informatics
joaomarco@di.uminho.pt

2024/2025